

PFSense FIREWALL POLICY

Creazione di una regola firewall che blocchi l'accesso alla DVWA di metasploitable2 dalla macchina virtuale Kali Linux e impedisca quindi lo scan.

REQUISITI OBBLIGATORI

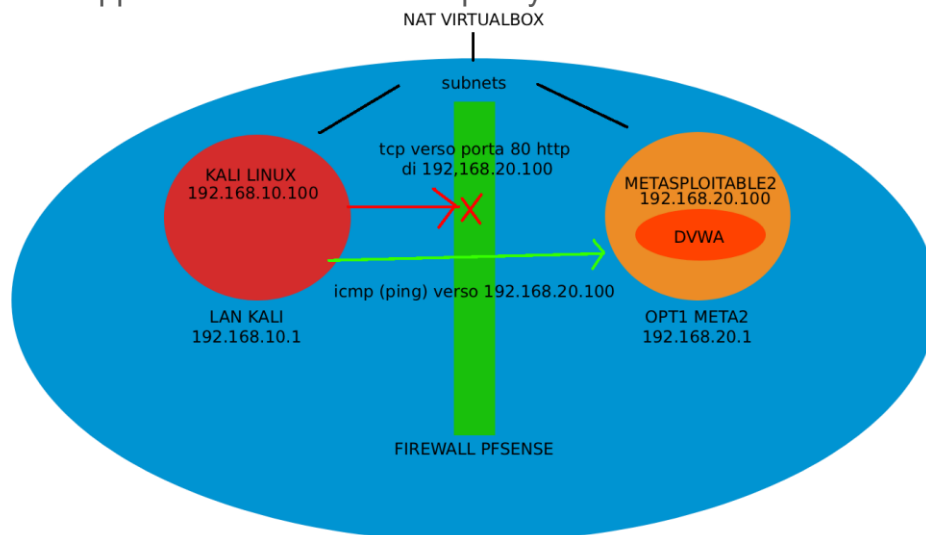
E' necessario che:

- Le macchine virtuali Kali Linux e Metasploitable siano su reti diverse
- Le due VM devono poter comunicare in qualsiasi altro modo consentito
- Le due VM non devono essere connesse ad internet (opzionale)

THOUGHT PROCESS

Step necessary:

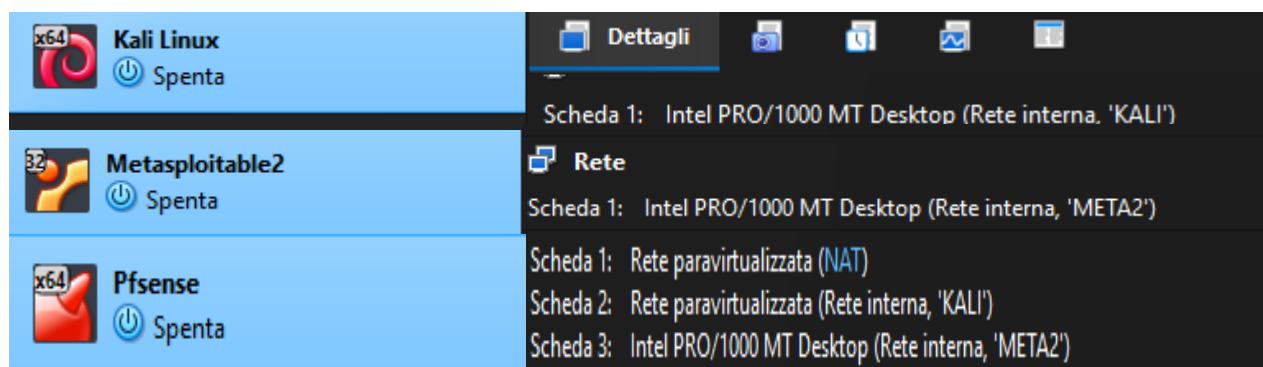
- Configurare reti interne delle VM su Virtualbox
- Configurare PFSense e aggiungere interfacce di rete corrispettive
- Attivare DVWA da metasploitable2 e (da GUI web su kali) accertarsi del funzionamento
- Creare regola firewall che blocchi traffico da Kali alla porta 80 http di Metasploitable2
- Testare applicazione corretta delle policy firewall



SETUP RETE INTERNE

Le macchine virtuali devono appartenere a subnet diversi, quindi utilizzare due reti interne a virtualbox che io chiamero corrispettivamente KALI e META2:

- Su impostazioni rete Kali scheda 1: Rete interna "KALI"
- Su impostazioni rete Metasploitable2 scheda 1: Rete interna "META2"
- Su impostazioni rete Pfsense scheda 1: NAT (la NAT di virtualbox, em0/WAN)
- Su impostazioni rete Pfsense scheda 2: Rete interna "KALI" (em1/LAN)
- Su impostazioni rete Pfsense scheda 3: Rete interna "META2" (em2/OPT1)



ASSEGNAZIONE INTERFACCE/IP PFSENSE

Ho bisogno ora di avviare Pfsense per configurare e assegnare le interfacce. WAN sarà la NAT interna di Virtualbox, LAN sarà la rete interna di Kali su scheda 2 (em1), OPT1 sarà la rete interna di Metasploitable2 su scheda 3 (em2). Dopodiché dovrò impostare gli IP di queste interfacce attraverso il CLI di Pfsense:

- Metto input "2" per "Set interface(s) IP address"
- Su LAN (em1) imposto ip: 192.168.10.1/24
- Su OPT1(em2) imposto ip: 192.168.20.1/24
- Non utilizzerò dhcp4 o dhcp6, le VM utilizzeranno IP statico on questo caso

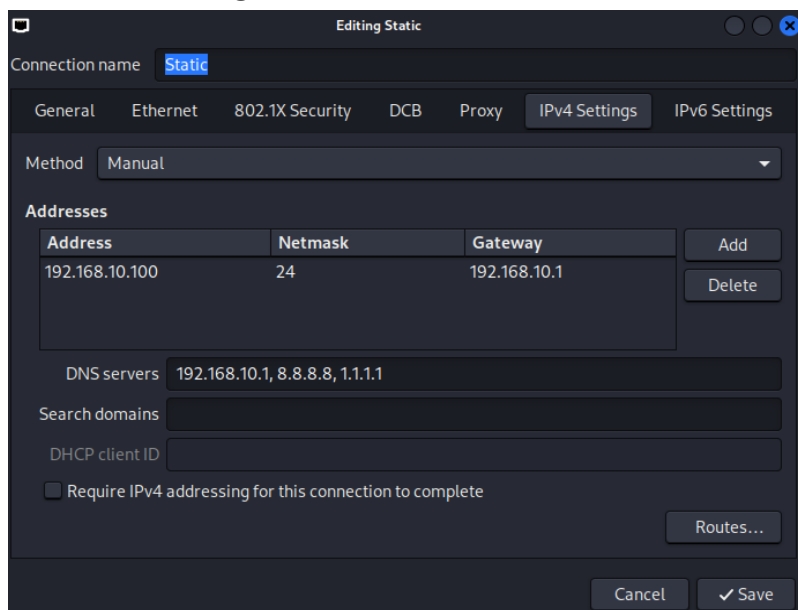
VM Kali: 192.168.10.100/24

VM Metasploitable2: 192.168.20.100/24

IMPOSTARE IP STATICI SU MACCHINE VIRTUALI

Come già spiegato, utilizzeremo IP statici sulle macchine virtuali.

- Su Kali agisco direttamente da GUI

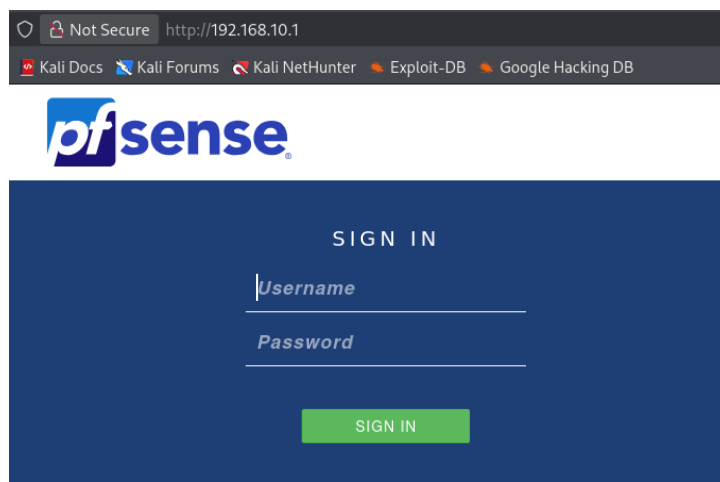


- Su Metasploitable2 invece è necessario
che io utilizzi CLI nella seguente modalità:

```
msfadmin@metasploitable:~$ sudo nano /etc/network/interfaces
```

PFSENSE WEB (SU BROWSER KALI)

Per accedere alla GUI web di pfsense devo ora inserire l'ip interfaccia LAN sul mio web browser, in questo caso 192.168.10.1; Qui posso accedere alle funzioni di amministrazione Pfsense principali come le policy firewall e la creazione di alias. Importante durante la prima configurazione rimuovere "Block RFC1928" altrimenti network privati non potranno comunicare tra loro.



RFC1918 Networks

Block RFC1918 Private Networks ☐ Block private networks from entering via WAN

When set, this option blocks traffic from IP addresses that are reserved for private networks as per RFC 1918 (10/8, 172.16/12, 192.168/16) as well as loopback addresses (127/8). This option should generally be left turned on, unless the WAN network lies in such a private address space, too.

- Come default il firewall non avrà alcuna policy su OPT1 quindi per essere sicuro che, almeno temporaneamente, Kali e Metasploitable2 possano comunicare io imposto le prime due regole firewall:

Edit Firewall Rule

Action Pass
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface LAN
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol Any
Choose which IP protocol this rule should match.

Source
Source ☐ Invert match LAN subnets Source Address /

Destination
Destination ☐ Invert match OPT1 subnets Destination Address /

Edit Firewall Rule

Action Pass
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface OPT1
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol Any
Choose which IP protocol this rule should match.

Source
Source ☐ Invert match OPT1 subnets Source Address /

Destination
Destination ☐ Invert match LAN subnets Destination Address /

DVWA (SU METASPLOITABLE2)

DVWA è pre-installato su metasploitable insieme ad apache2, quindi controllo se questo è già attivo (in questo caso sì) e se è già in ascolto su porta 80.

```
msfadmin@metasploitable:~$ sudo /etc/init.d/apache2 start
* Starting web server apache2
```

```
msfadmin@metasploitable:~$ netstat -tlnp | grep :80
(No info could be read for "-p": geteuid()=1000 but you should be root.)
tcp        0      0 0.0.0.0:8009        0.0.0.0:*          LISTEN
-
tcp        0      0 0.0.0.0:80         0.0.0.0:*          LISTEN
```

CREAZIONE DATABASE DVWA (SU BROWSER KALI)

Ora devo andare su browser kali (per comodità) per creare il database DVWA di metasploitable2 dove verranno conservati i dati di sessione, inoltre imposto il security level a "low" (so che non funziona da web GUI per questa versione, provato comunque)

The screenshot shows the DVWA Security web application interface. On the left is a sidebar with navigation links: Home, Instructions, Setup (highlighted), Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, About, and Logout. The main content area has a header with the DVWA logo and a 'Database setup' section. Below this, there's a 'Create / Reset Database' button. The main heading is 'DVWA Security' with a padlock icon, followed by 'Script Security'. The text indicates the 'Security Level is currently low' and allows setting it to low, medium, or high. At the bottom, there's a dropdown menu set to 'low' and a 'Submit' button. The footer shows 'Username: Security Level: high PHPIDS: disabled'.

TEST PER CONFIGURAZIONE RETI

Per essere sicuri che le macchine virtuali possano comunicare tra loro, includendo anche da Kali su porta 80 PRIMA di impostare policy firewall, eseguo questi test:

- Metasploitable2 può comunicare con em2 PFsense (192.168.20.1)

```
msfadmin@metasploitable:~$ ping 192.168.20.1
PING 192.168.20.1 (192.168.20.1) 56(84) bytes of data.
64 bytes from 192.168.20.1: icmp_seq=1 ttl=64 time=36.9 ms
64 bytes from 192.168.20.1: icmp_seq=2 ttl=64 time=106 ms
64 bytes from 192.168.20.1: icmp_seq=3 ttl=64 time=39.4 ms
64 bytes from 192.168.20.1: icmp_seq=4 ttl=64 time=8.95 ms

--- 192.168.20.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3710ms
rtt min/avg/max/mdev = 8.957/47.883/106.220/35.742 ms
msfadmin@metasploitable:~$
```

- Kali può comunicare con em1 PFsense (192.168.10.1)

```
(kali@kali)-[~]
$ ping 192.168.10.1
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data.
64 bytes from 192.168.10.1: icmp_seq=1 ttl=64 time=0.652 ms
64 bytes from 192.168.10.1: icmp_seq=2 ttl=64 time=0.631 ms
64 bytes from 192.168.10.1: icmp_seq=3 ttl=64 time=0.707 ms
64 bytes from 192.168.10.1: icmp_seq=4 ttl=64 time=0.661 ms
64 bytes from 192.168.10.1: icmp_seq=5 ttl=64 time=0.777 ms
64 bytes from 192.168.10.1: icmp_seq=6 ttl=64 time=0.608 ms
64 bytes from 192.168.10.1: icmp_seq=7 ttl=64 time=0.608 ms
64 bytes from 192.168.10.1: icmp_seq=8 ttl=64 time=0.664 ms
64 bytes from 192.168.10.1: icmp_seq=9 ttl=64 time=0.775 ms
^C
--- 192.168.10.1 ping statistics ---
9 packets transmitted, 9 received, 0% packet loss, time 8162ms
rtt min/avg/max/mdev = 0.608/0.675/0.777/0.060 ms
```

- Kali può accedere a porta 80http per raggiungere DVWA di metasploitable2

```
(kali@kali)-[~]
$ curl http://192.168.20.100/dwva
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /dwva was not found on this server.</p>
<hr>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.20.100 Port 80</address>
</body></html>
```

ricevo l'HTML corrispettivo invece di un time out, quindi è un successo.

ALIAS METASPLOITABLE2 E APPLICAZIONE POLICY FIREWALL (SU BROWSER KALI)

Ora creo su gui web Pfsense un alias di metasploitable2 così che successivamente possa bloccarlo come destinazione da policy firewall con specifiche porte d'interesse, in questo caso proprio la porta 80 http in listening di apache2 per DVWA, così che Kali non possa comunicare con essa.

Firewall Aliases IP				
Name	Type	Values	Description	Actions
MetasploitableIP	Host(s)	192.168.20.100		  

Infine posso aggiungere una nuova regola firewall a LAN che blocchi tutti i pacchetti TCP dal subnet di LAN verso l'alias di Metasploitable2 nelle porte d'interesse. Importante mettere il range custom porta di destinazione 80

Edit Firewall Rule

Action

Block

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

LAN

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

TCP

Choose which IP protocol this rule should match.

Source

Source

☐ Invert match

LAN subnets

Source Address

/

Display Advanced

The **Source Port Range** for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, **any**.

Destination

Destination

☐ Invert match

Address or Alias

192.168.20.100

/

Destination Port Range

(other)

80

(other)

80

From

Custom

To

Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	✓ 9/579 KIB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	
☐	✗ 0/0 B	IPv4 TCP	LAN subnets	*	192.168.20.100	80 (HTTP)	*	none			   
☐	✓ 0/0 B	IPv4 *	LAN subnets	*	OPT1 subnets	*	*	none		Traffico di alcun tipo consentito LAN->OPT1	    
☐	✓ 4/903 KIB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	    
☐	✓ 0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	    

TEST FINALE

Ora posso controllare se il traffico verso la porta 80 sia disabilitato grazie alla nuova firewall policy e se gli altri protocolli invece possano essere comunque utilizzati.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ curl http://192.168.20.100/dwva
```

- Provando a raggiungere la porta http 80 con la richiesta curl verso la DVWA di metasploitable2 ora invece sono “timed-out” e non ricevo più reply dalla dvwa

```
(kali@kali)-[~]  
$ curl http://192.168.20.100/dwva  
^C  
(kali@kali)-[~]  
$ ping 192.168.20.100  
PING 192.168.20.100 (192.168.20.100) 56(84) bytes of data.  
64 bytes from 192.168.20.100: icmp_seq=1 ttl=63 time=28.0 ms  
64 bytes from 192.168.20.100: icmp_seq=2 ttl=63 time=73.7 ms  
64 bytes from 192.168.20.100: icmp_seq=3 ttl=63 time=6.72 ms  
^C  
— 192.168.20.100 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2003ms  
rtt min/avg/max/mdev = 6.723/36.171/73.746/27.958 ms
```

invece è ancora possibile da Kali mandare altri tipi di richieste o usare altri servizi.